

Bachelor of Information System

IS2204 - Information System Security

Lecture – 6 : TLS

Kasun De Zoysa
kasun@ucsc.cmb.ac.lk



UNIVERSITY OF COLOMBO SCHOOL OF COMPUTING



Cybersecurity Protocols

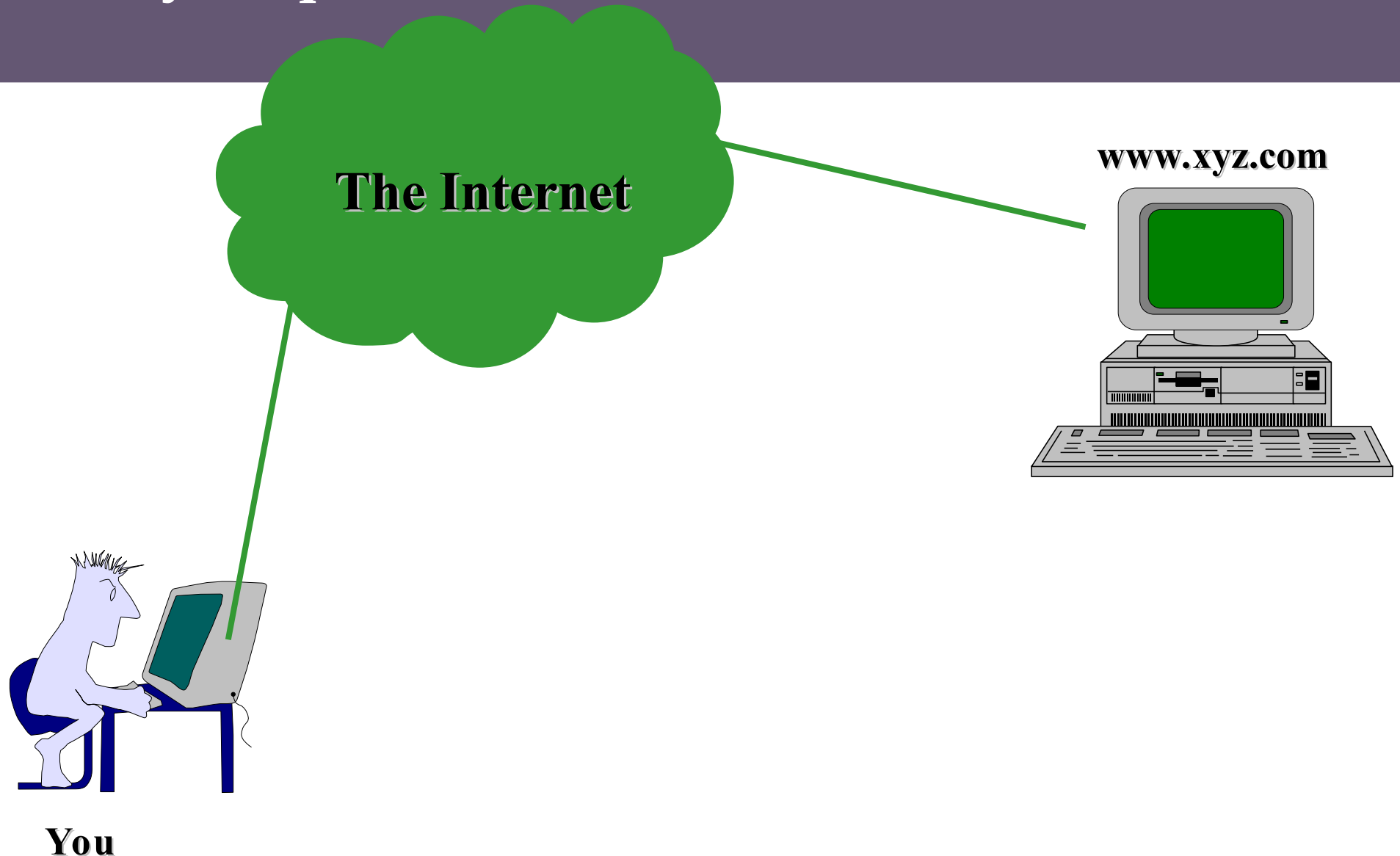
-
- **PGP** : E-Mail, RFC2015
 - **S/MIME** : E-Mail, RFC2311,RFC2634
- } Email Security
-
- **S-HTTP** : Web Browsing, RFC2660
 - **PCT** : TCP/IP-level Encryption
 - **SSL** : TCP/IP-level Encryption, Netscape
 - **TLS** : TCP/IP-level Encryption, RFC2246
- } Web Security
-
- **Cybercash** : Electronic Transactions, RFC1898
 - **SET** : Secure Electronic Funds Transactions
 - **BitCoin**: Blockchain Cryptocurrencies
- } Payment Security
-
- **SSH** : Remote Login
 - **DNSSEC** : Domain Name System, RFC2065
 - **IPSec** : Packet-Level Encryption, RFC2401
 - **Tor**: Onion Routing Protocol
- } Network Security
-

Security Wisdom

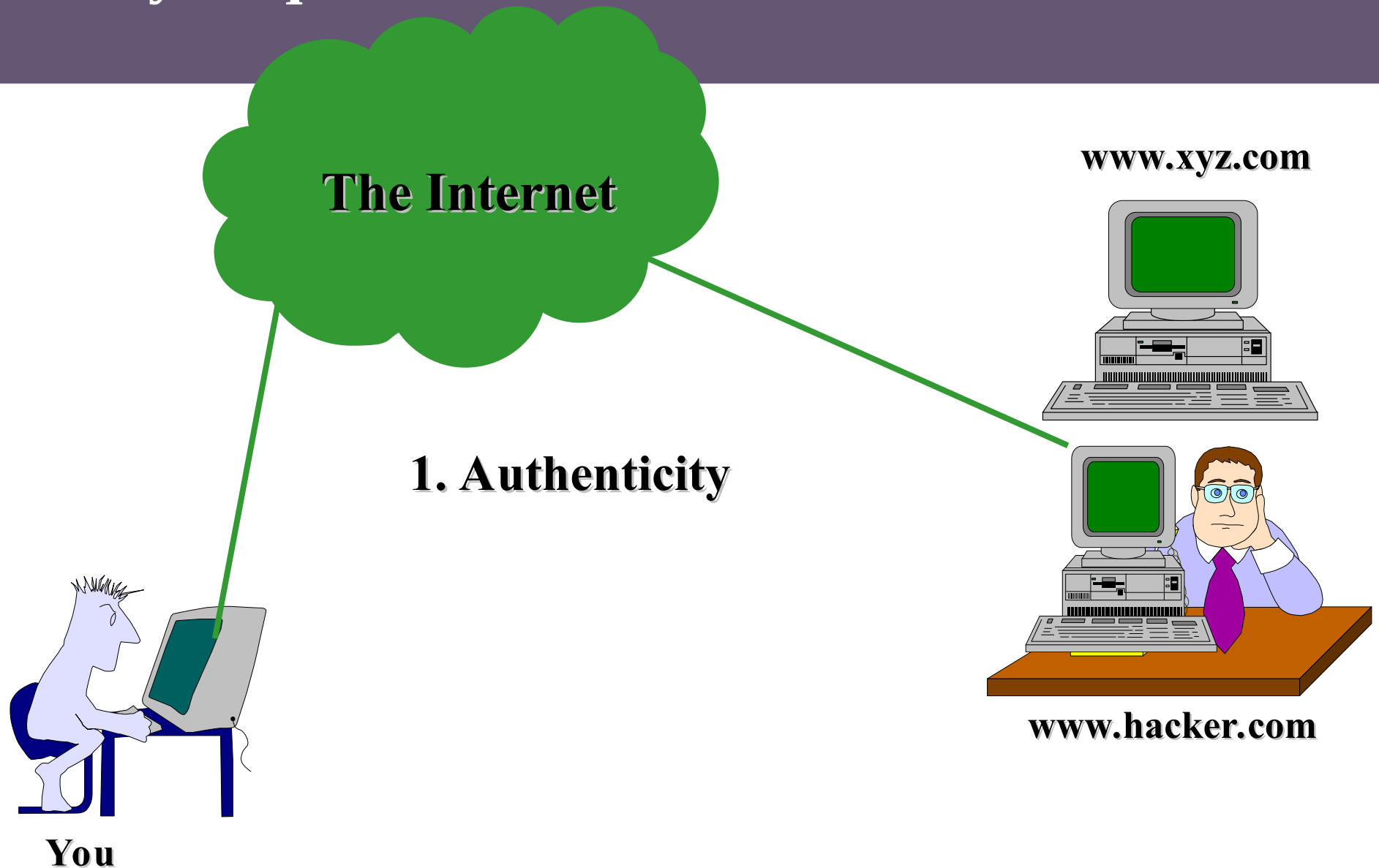
- **Popular Myth:**
Information Security depends on...
 - firewalls
 - SSL
 - Virus Scanners or IDS
- **Unpopular Reality:**
In a large, Information security is not achieved by above technologies.



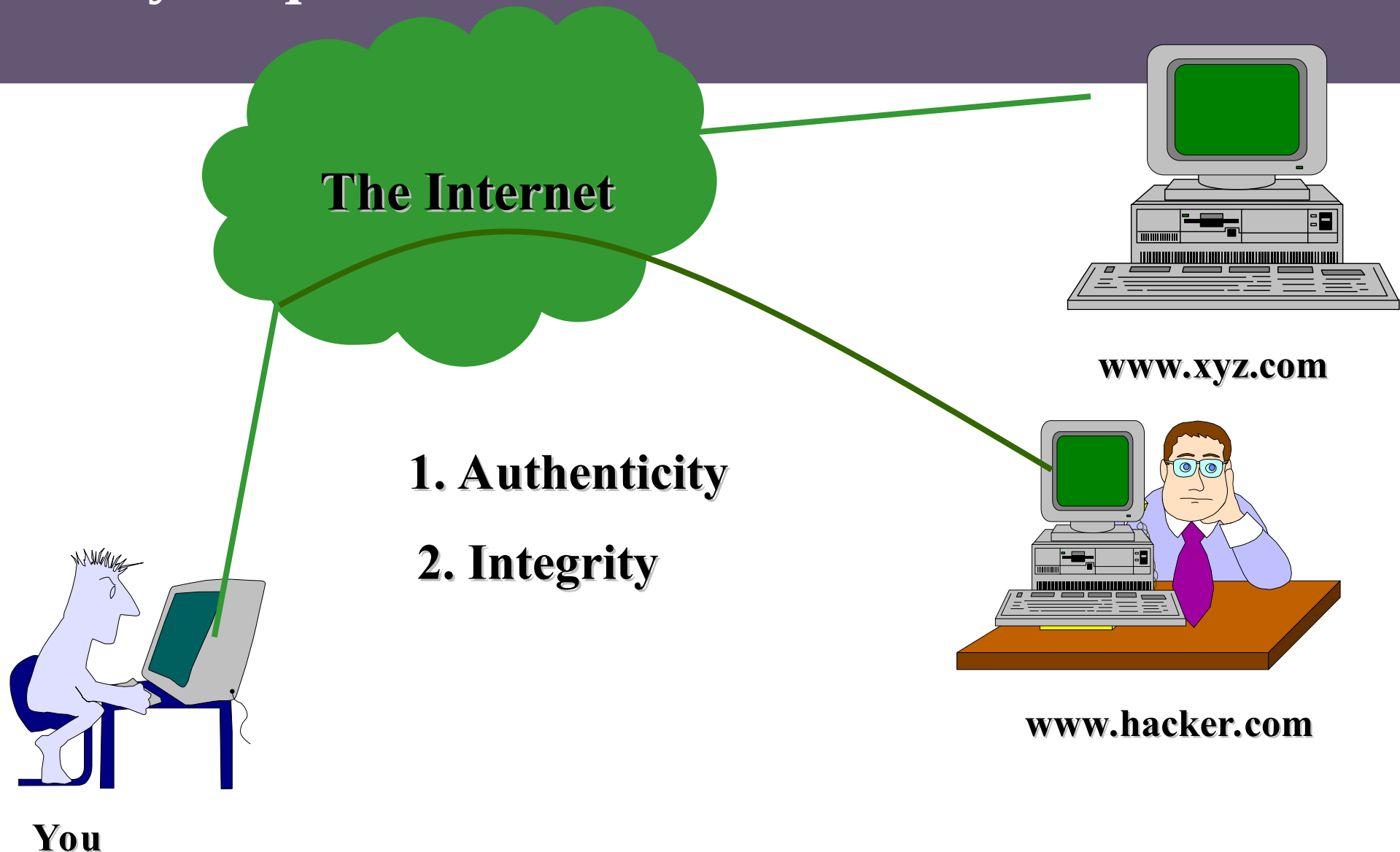
Security Requirements and User Needs



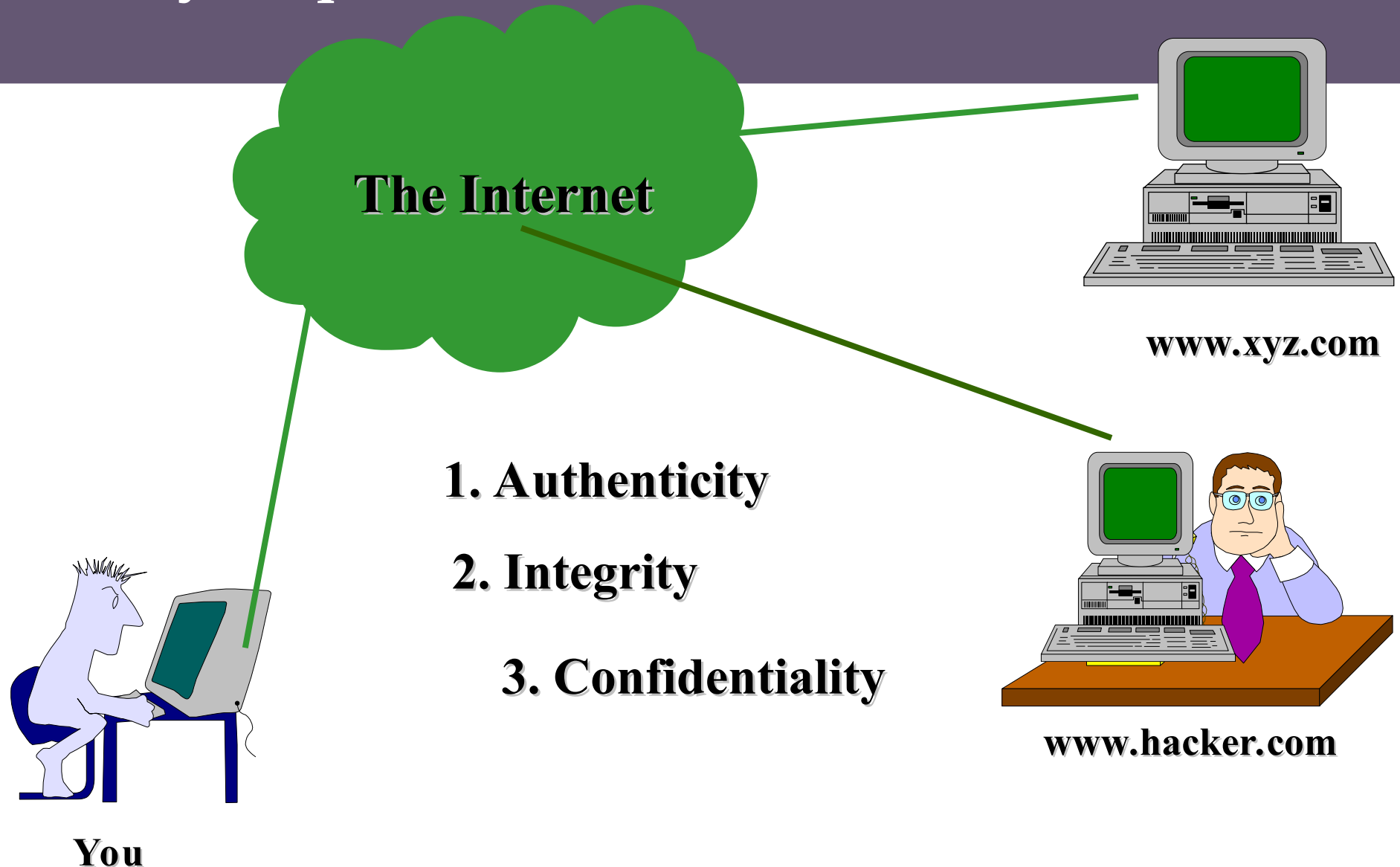
Security Requirements and User Needs



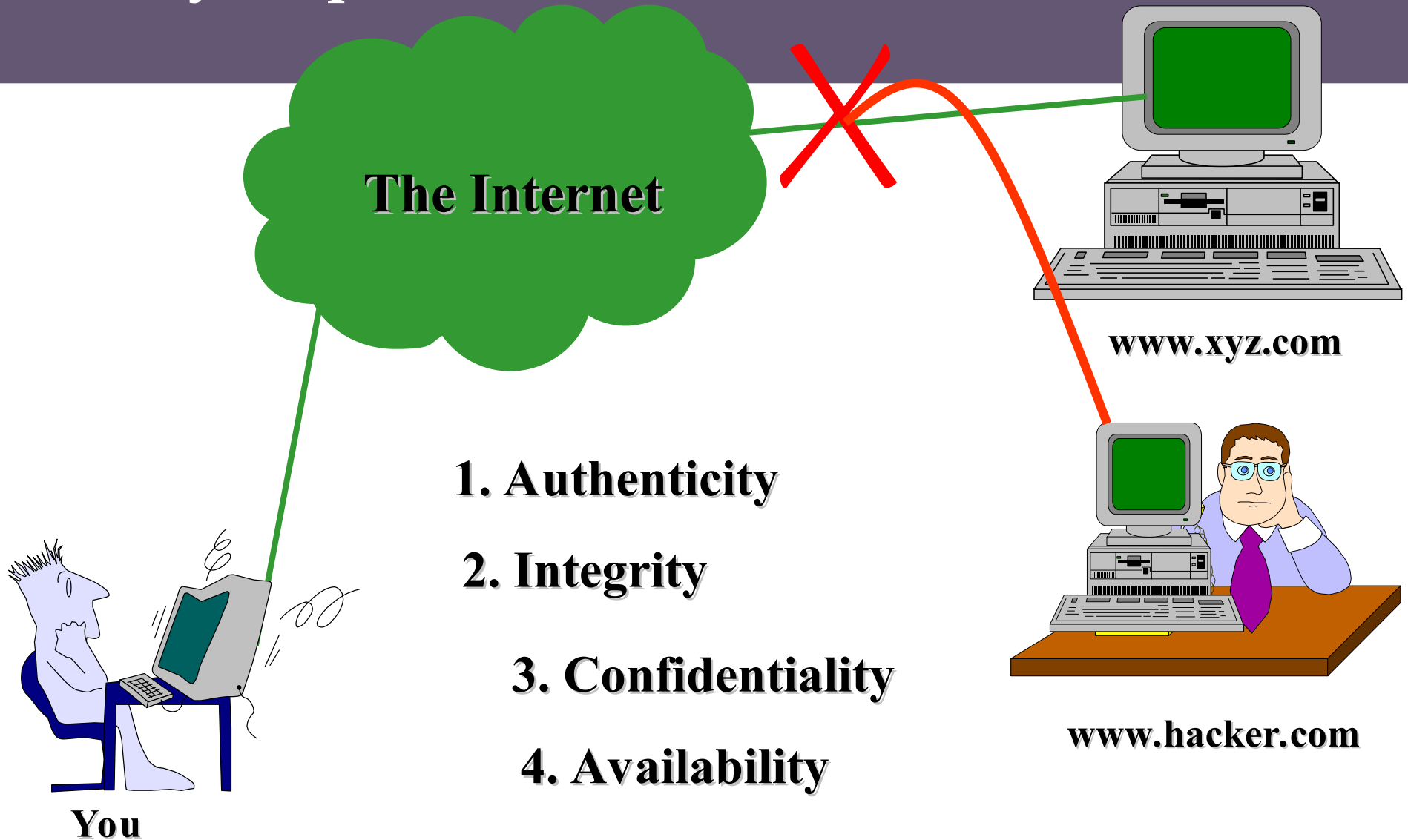
Security Requirements and User Needs



Security Requirements and User Needs

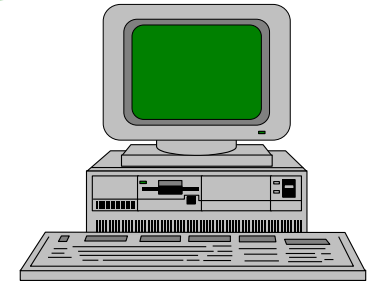


Security Requirements and User Needs



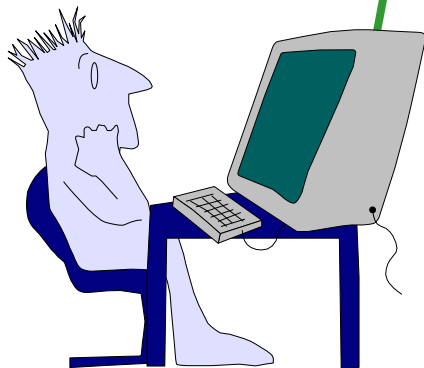
Security Requirements and User Needs

The Internet

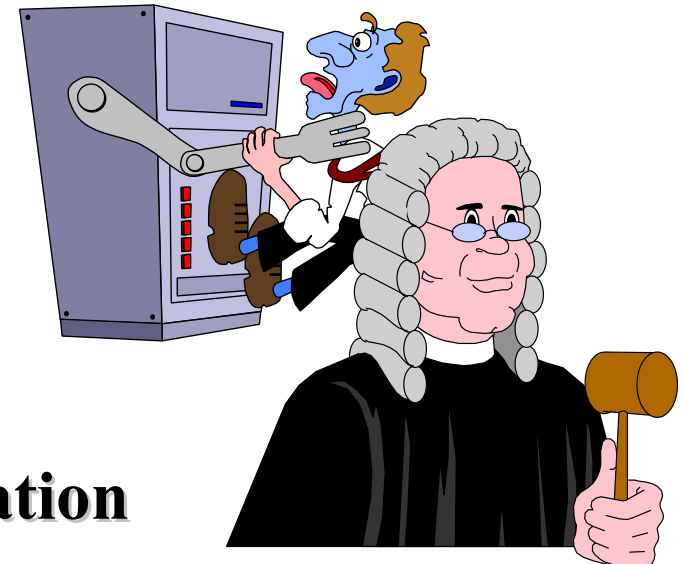


www.xyz.com

- 1. Authenticity**
- 2. Integrity**
- 3. Confidentiality**
- 4. Availability**
- 5. Non-repudiation**



You



Secure Socket Layer History

- SSL 1.0 Netscape 1994
- S-HTTP (web only)
- SSL 2.0 Netscape (buggy)
- PCT Microsoft (loser) 1996
- SSL 3.0 Netscape
- TLS 1.0 IETF 1999
- TLS 1.2 now dominant

TLS: Transport Layer Security

- *formerly known as*
SSL: Secure Sockets Layer
- Addresses issues of privacy, integrity and authentication
 - What is it?
 - How does it address the issues?
 - How is it used

TLS

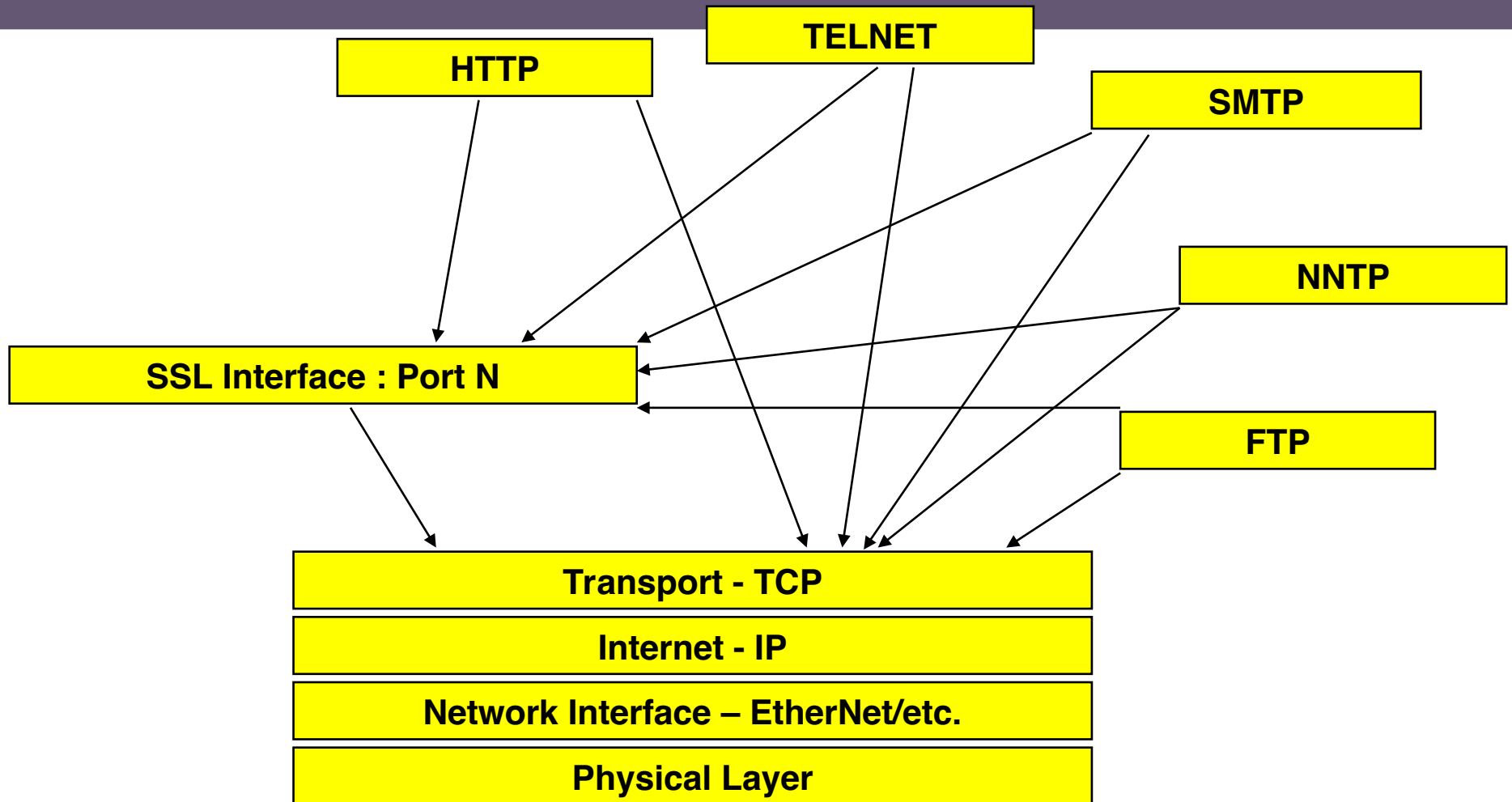
- “TLS, more commonly known as SSL”
- RFC2246 : TLS Protocol Version 1.0 1/99
- RFC2487 : SMTP over TLS
- RFC2712 : Adding Kerberos to TLS
- RFC2716 : PPP TLS
- RFC2817 : Upgrading to TLS within HTTP/1.1
- RFC2818 : HTTP over TLS
- RFC2830 : TLS for Lightweight Directory Access Protocol (LDAP)

What is TLS?

- Protocol layer
- Requires reliable transport layer (e.g. TCP)
- Supports any application protocols

HTTP	Telnet	FTP	LDAP
TLS			
TCP			
IP			

Protocol Stack

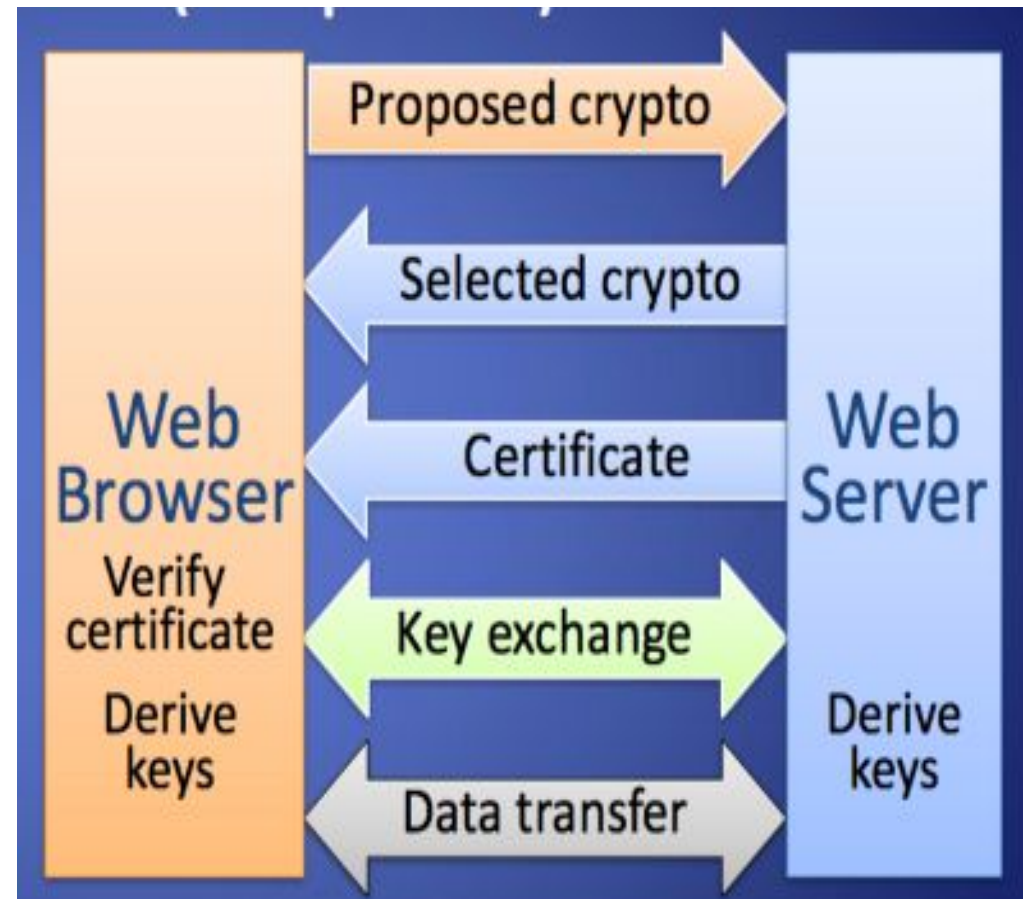


TLS: Overview

- Establish a session
 - Agree on algorithms
 - Share secrets
 - Perform authentication
- Transfer application data
 - Ensure privacy and integrity

TLS Overview

- Browser sends supported crypto algorithms
- Server picks strongest algorithms it supports
- Server sends certificate (chain)
- Client verifies certificate (chain)
- Client and server agree on secret value R by exchanging messages
- Secret value R is used to derive keys for symmetric encryption and hash-based authentication of subsequent data transfer

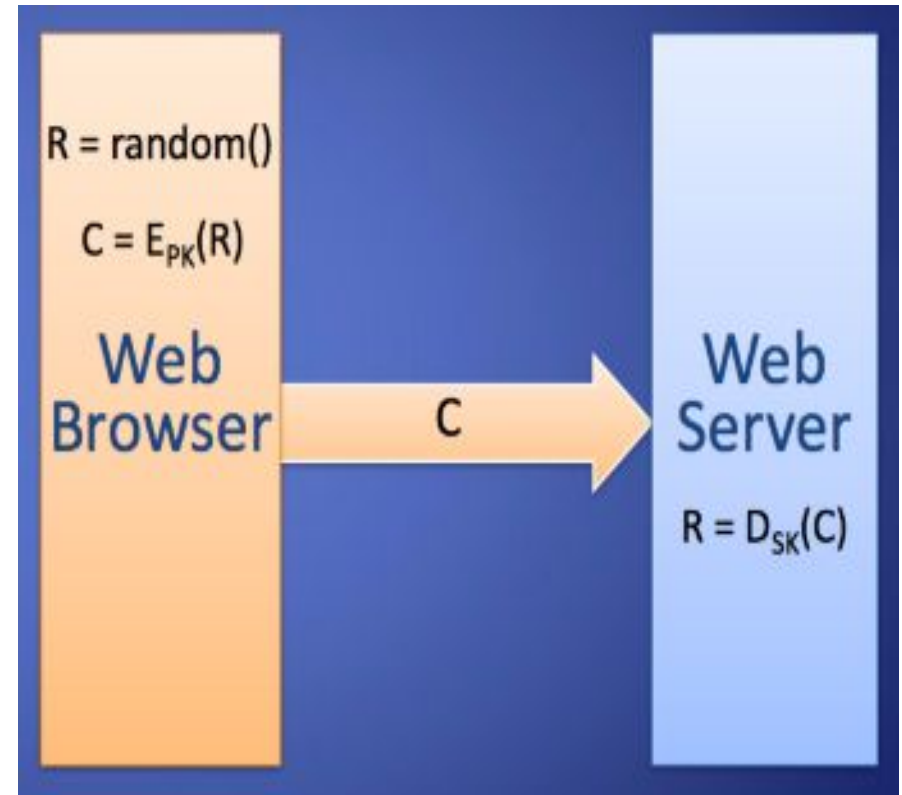


TLS:Key Exchange

- Need secure method to exchange secret key
- Use public key encryption for this
 - “key pair” is used - either one can encrypt and then the other can decrypt
 - slower than conventional cryptography
 - share one key, keep the other private
- Choices are RSA or Diffie-Hellman

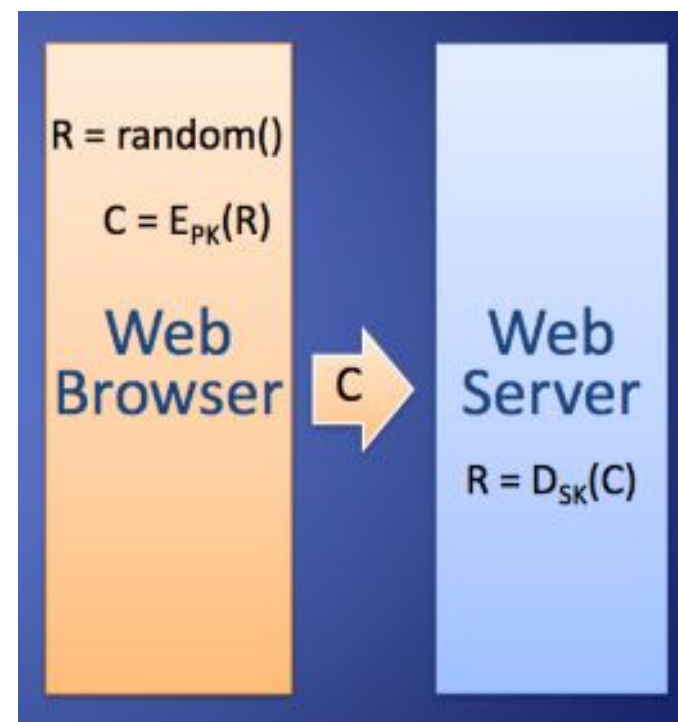
Basic Key Exchange

- Called RSA key exchange for historical reasons
- Client generates random secret value R
- Client encrypts R with public key, PK , of server $C = E_{PK}(R)$
- Client sends C to server
- Server decrypts C with private key, SK , of server $R = D_{SK}(C)$

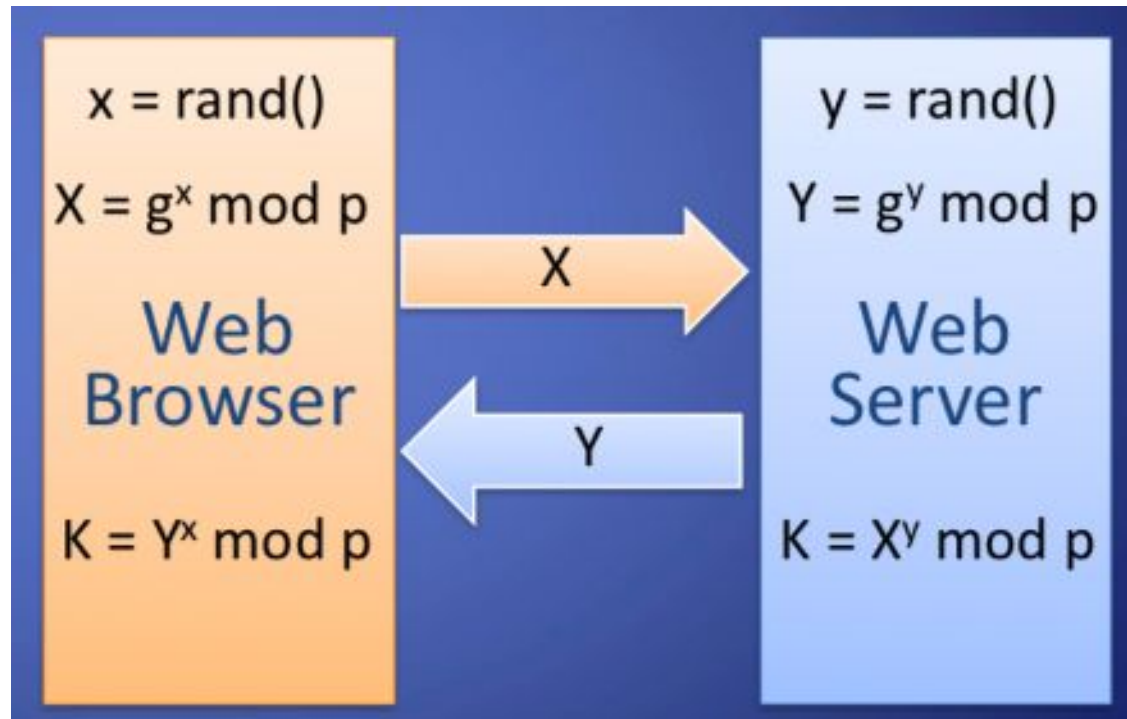


Forward Secrecy

- Compromise of public-key encryption private keys does not break confidentiality of past messages
- TLS with basic key exchange does not provide forward secrecy
- Attacker eavesdrop and stores communication
- If server's private key is compromised, attacker finds secret value R in key exchange and derives encryption keys

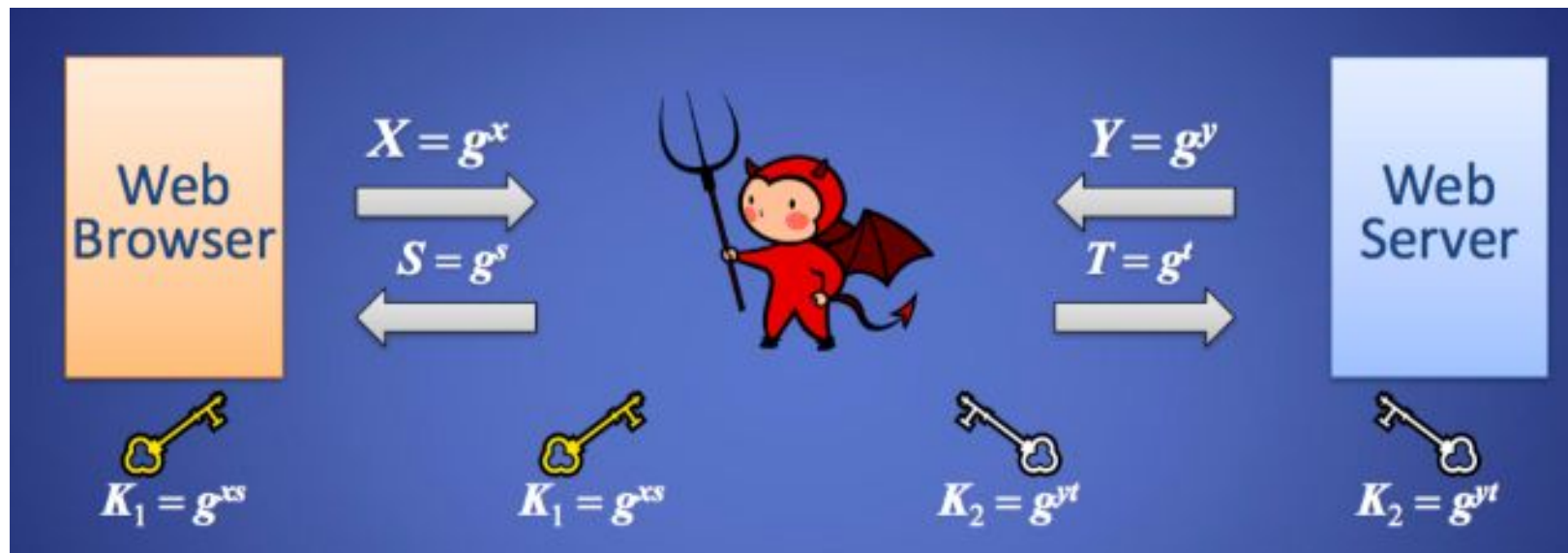


Diffie Hellman Key Exchange



Achieves forward secrecy

Attacker in the Middle



Solution:

Browser and server send signed X and Y respectively
Requires each to know the public key of the other

TLS: Privacy

- Encrypt message so it cannot be read
- Use conventional cryptography with shared key
 - DES, 3DES, AES
 - RC2, RC4
 - IDEA



TLS Encrypts

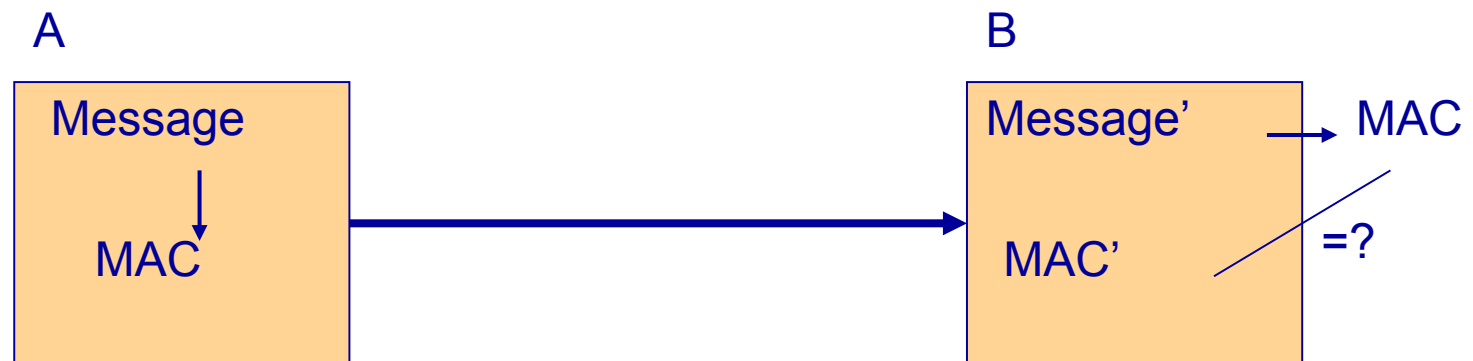
- ALL Browser-Server and Server-Browser except which-browser is talking to which-server
- URL of requested document
- Contents of requested document
- Contents of any submitted form fill-outs
- Cookies sent from browser to server
- Cookies sent from server to browser
- Contents of HTTP header
- Javascript communications
- Etc.

TLS: Integrity

- Compute fixed-length Message Authentication Code (MAC)
 - Includes hash of message
 - Includes a shared secret
 - Include sequence number
- Transmit MAC with message

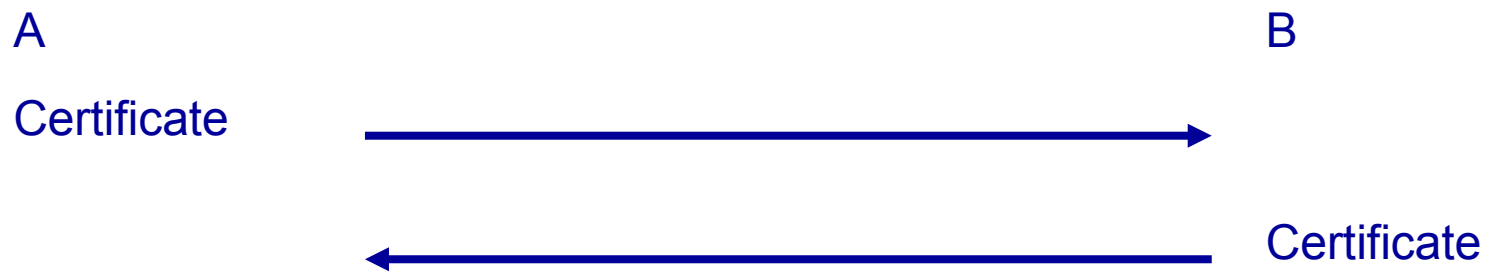
TLS: Integrity

- Receiver creates new MAC
 - should match transmitted MAC
- TLS allows MD5, SHA-1

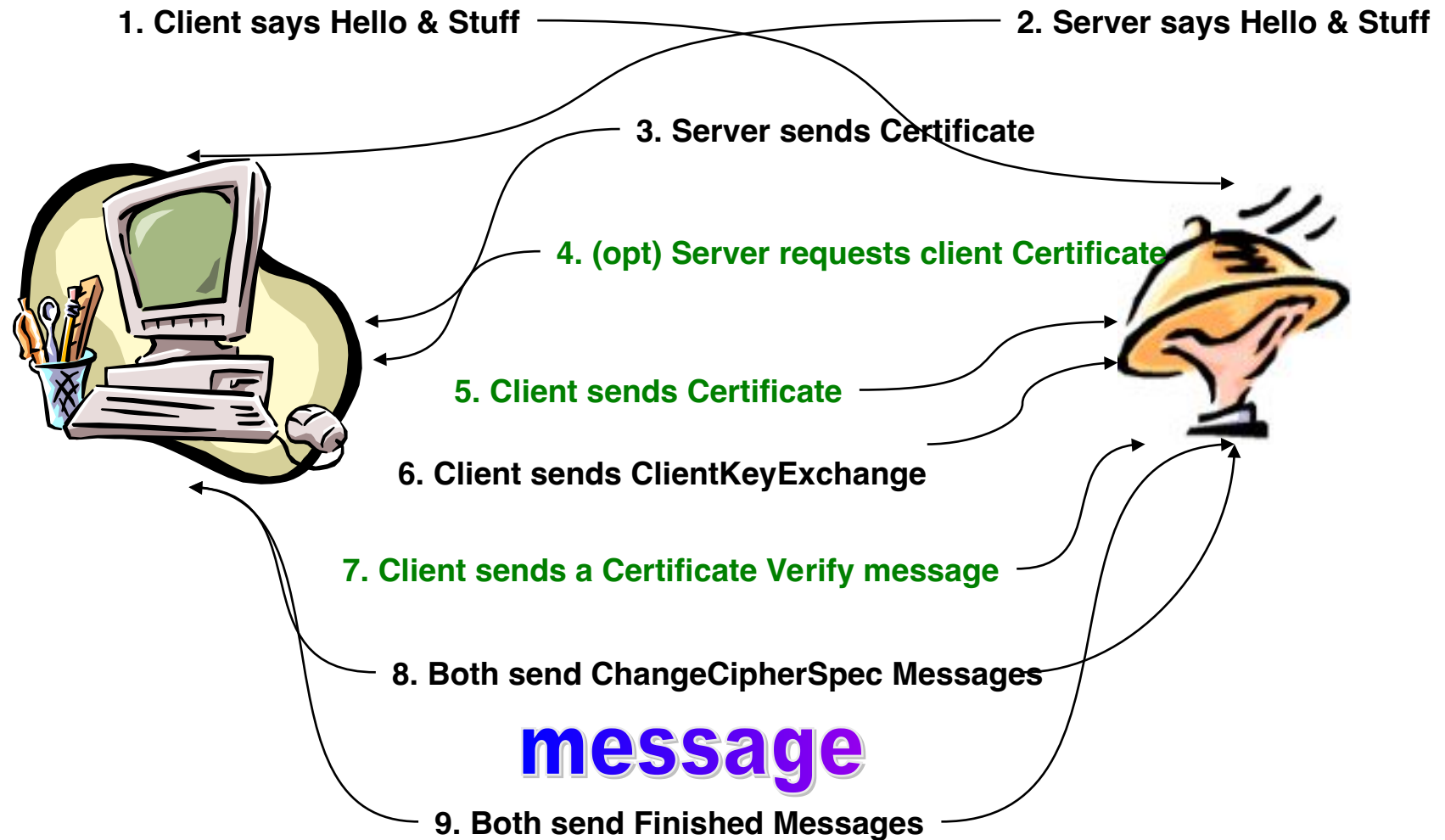


TLS: Authentication

- Verify identities of participants
- Client authentication is optional
- Certificate is used to associate identity with public key and other attributes

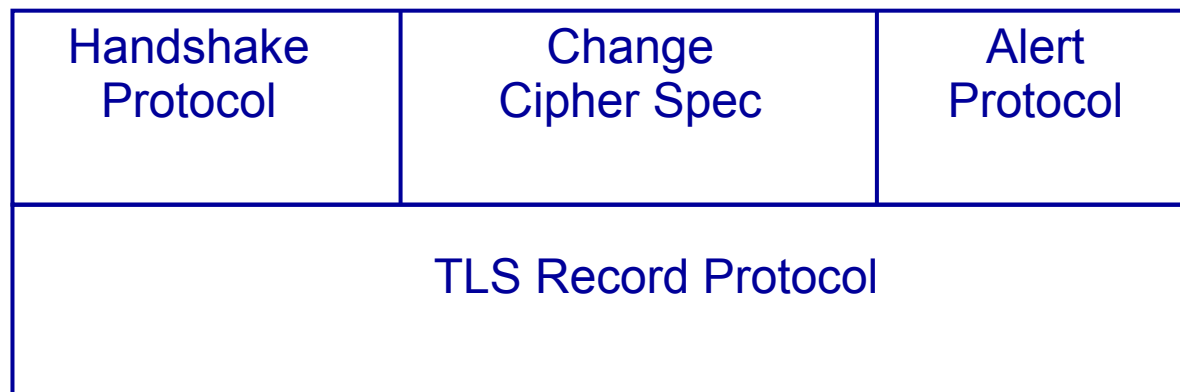


TLS Transaction

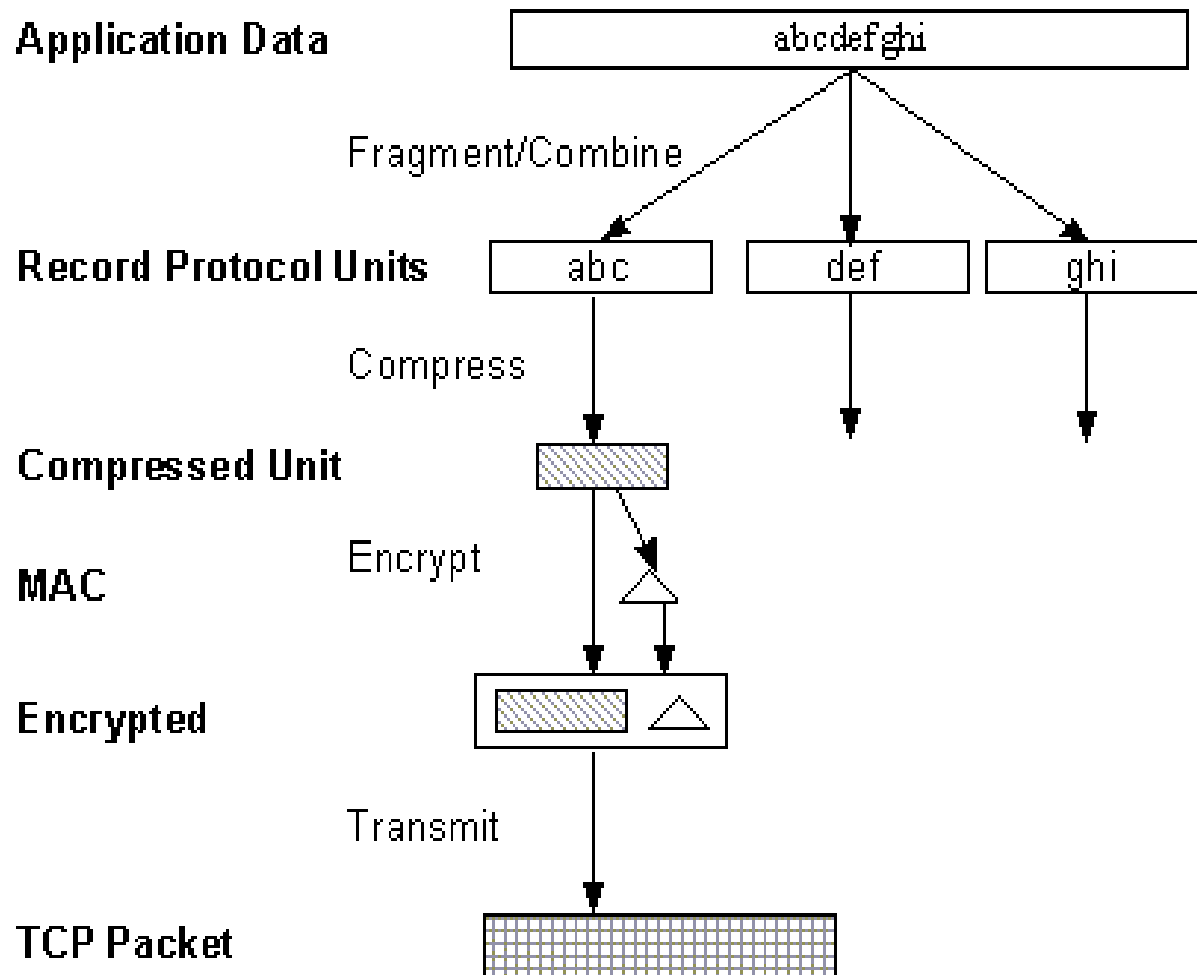


TLS: Architecture

- TLS defines Record Protocol to transfer application and TLS information
- A session is established using a Handshake Protocol



TLS: Record Protocol



TLS: HTTP Application

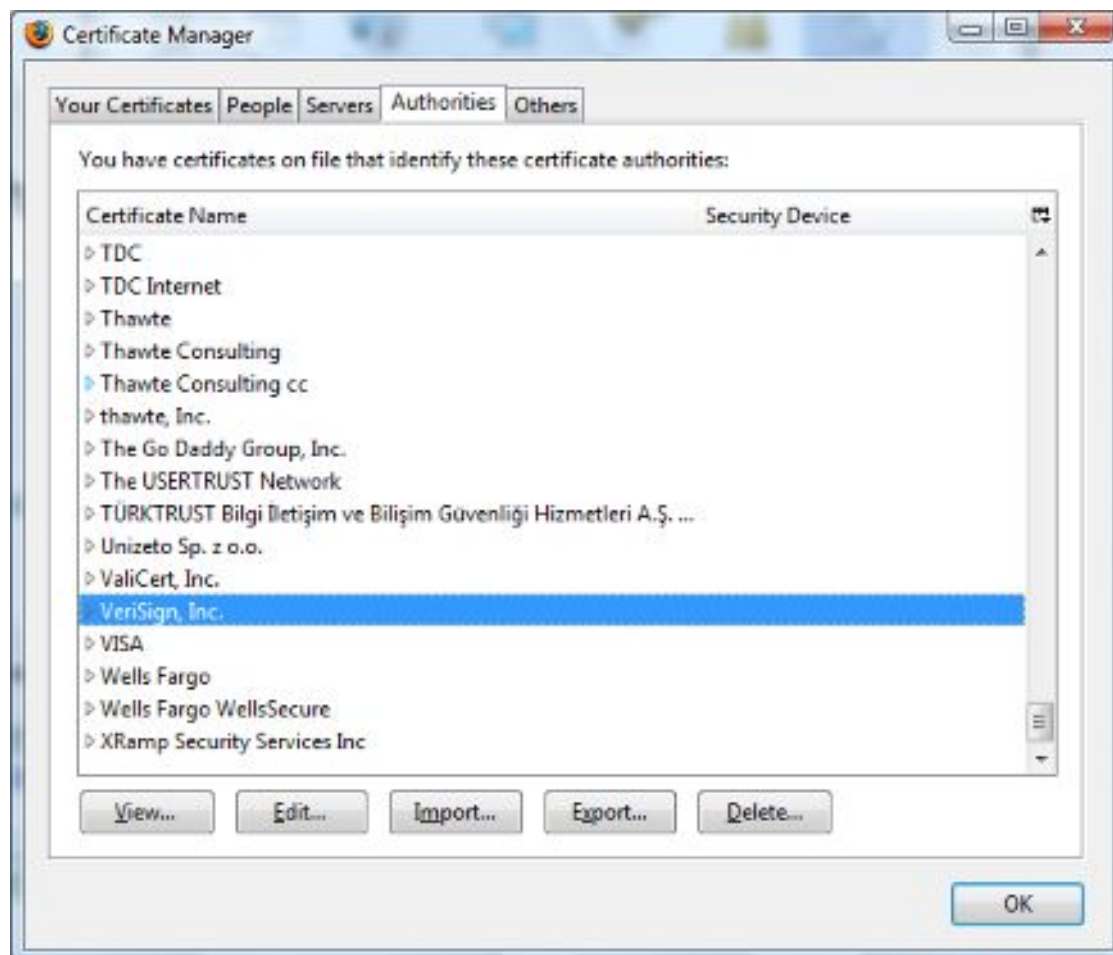
- HTTP most common TLS application
 - https://
- Requires TLS-capable web server
- Requires TLS-capable web browser
 - Netscape Navigator
 - Internet Explorer
 - Cryptozilla
 - Netscape Mozilla sources with SSLeay

Validating a Certificate

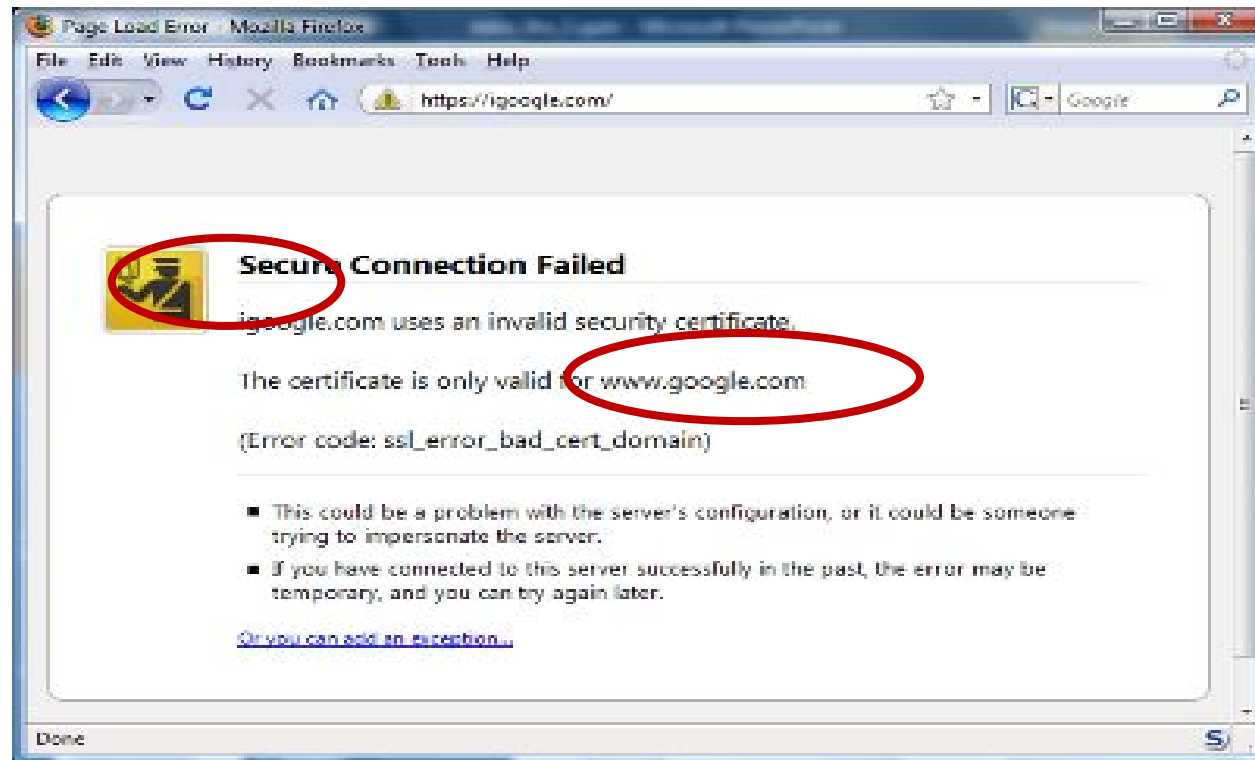
- Must recognize accepted CA in certificate chain
 - One CA may issue certificate for another CA
- Must verify that certificate has not been revoked
 - CA publishes Certificate Revocation List (CRL)

Certificate Authorities

Browsers accept
certificates from a
large number of CAs



Firefox: Invalid cert dialog



Firefox 3.0: Four clicks to get firefox to accept cert

- page is displayed with full HTTPS indicators

Version 3 Certificates

- Version 3 X.509 Certificates support alternative name formats as extensions
 - X.500 names
 - Internet domain names
 - e-mail addresses
 - URLs
- Certificate may include more than one name

HTTP Strict Transport Security

HTTP Strict Transport Security (HSTS) is a web security policy mechanism that helps to protect websites against protocol downgrade attacks and cookie hijacking.

It allows web servers to declare that web browsers (or other complying user agents) should interact with it using only HTTPS connections, which provide Transport Layer Security (TLS/SSL), unlike the insecure HTTP used alone.

SSLABS – www.ssllabs.com

HOW WELL DO YOU KNOW SSL?

If you want to learn more about the technology that protects the Internet, you've come to the right place.



Test your server »

Test your site's certificate and configuration



Test your browser »

Test your browser's SSL implementation



SSL Pulse »

See how other web sites are doing



Documentation »

Learn how to deploy SSL/TLS correctly

Summary

Overall Rating



Certificate
Protocol Support
Key Exchange
Cipher Strength



HSTS Apache

Edit your apache configuration file (/etc/apache2/sites-enabled/website.conf and /etc/apache2/httpd.conf for example) and add the following to your VirtualHost:

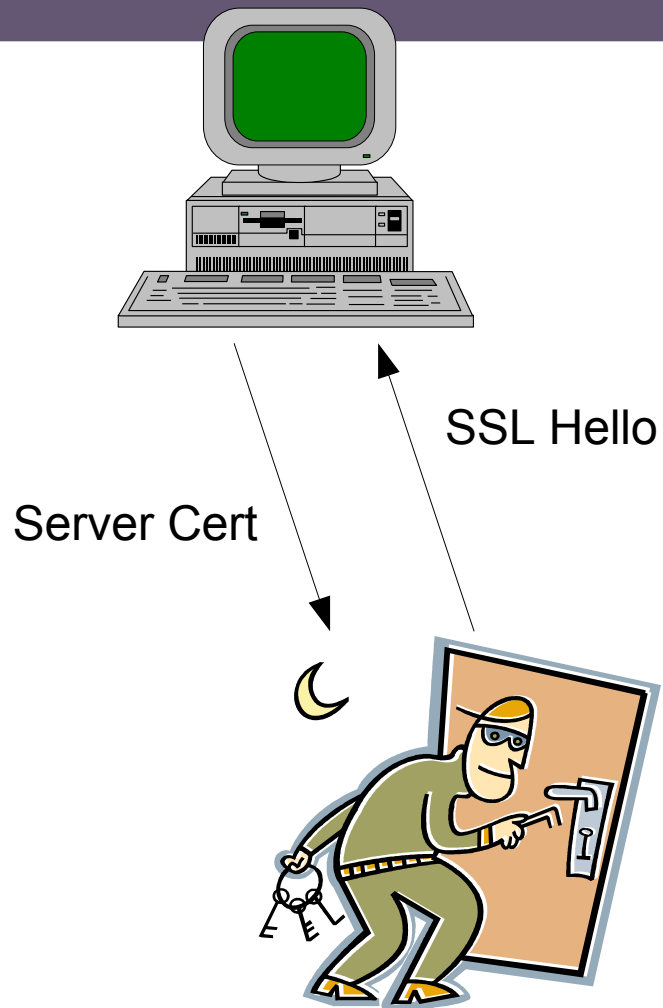
```
# Optionally load the headers module:  
LoadModule headers_module modules/mod_headers.so  
  
<VirtualHost 67.89.123.45:443>  
    Header always set Strict-Transport-Security "max-age=63072000; includeSubdomains;"  
</VirtualHost>
```

Let's Encrypt

The image shows two overlapping browser windows. The top window is the Let's Encrypt website (letsencrypt.org). It features the Let's Encrypt logo (a sun with a padlock) and navigation links: Documentation, Get Help, Donate, About Us, and Languages. The main content area states: "A nonprofit Certificate Authority providing TLS certificates to **180 million** websites." Below this, it says "Read our 2019 Annual Report (Desktop, Mobile)" and has two buttons: "Get Started" and "Sponsor".

The bottom window is the Certbot website (certbot.eff.org). It features the Certbot logo (a robot holding a key) and navigation links: certbot instructions, about certbot, contribute to certbot, hosting providers with https, get help, and donate. The main content area says "Get your site on https://". Below this, there are two input fields: one with a padlock icon and a toggle switch, and another with the text "\$ install certbot".

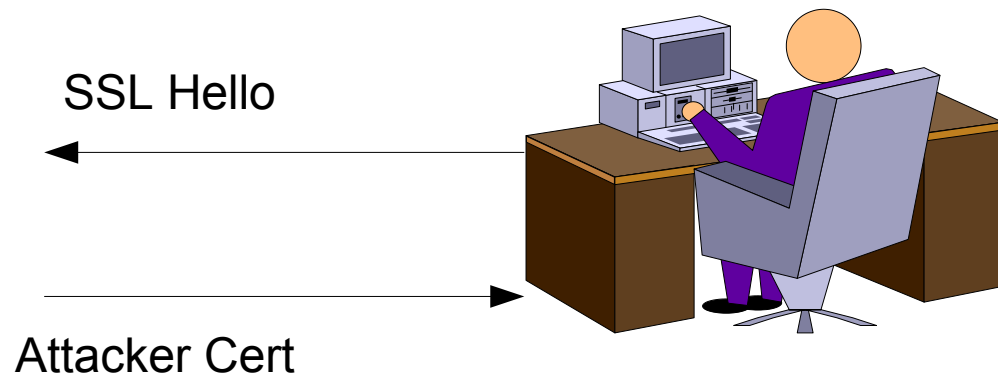
Man in the Middle



Attacker's proxy server establishes SSL session with a user

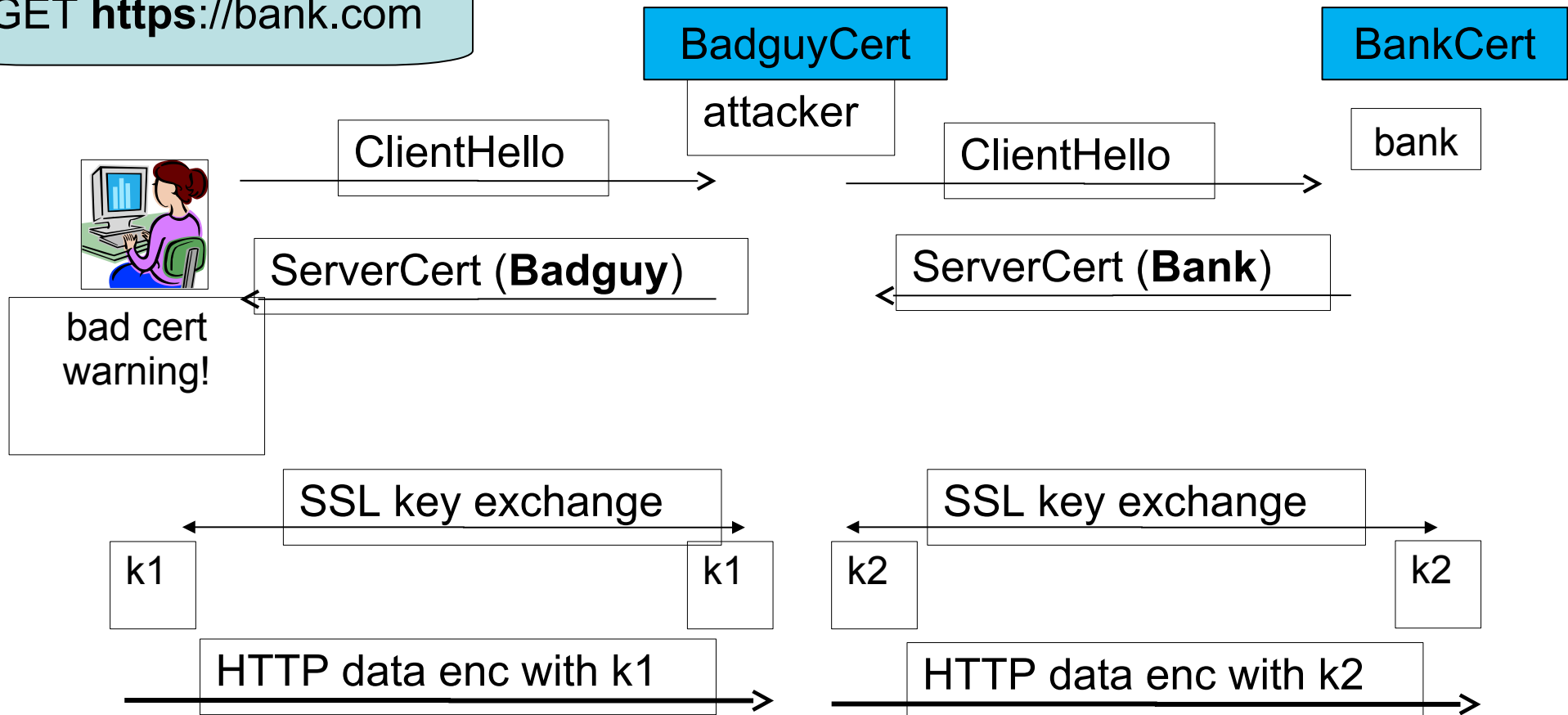
Attacker's proxy server establishes a session with the server

Attacker's proxy sever decrypts the data from the user and encrypts it back to the server



Man in the middle attack using invalid certs

GET <https://bank.com>



Attacker proxies data between user and bank.
Sees all traffic and can modify data at will.

OWASP

Open Web Application Security Project

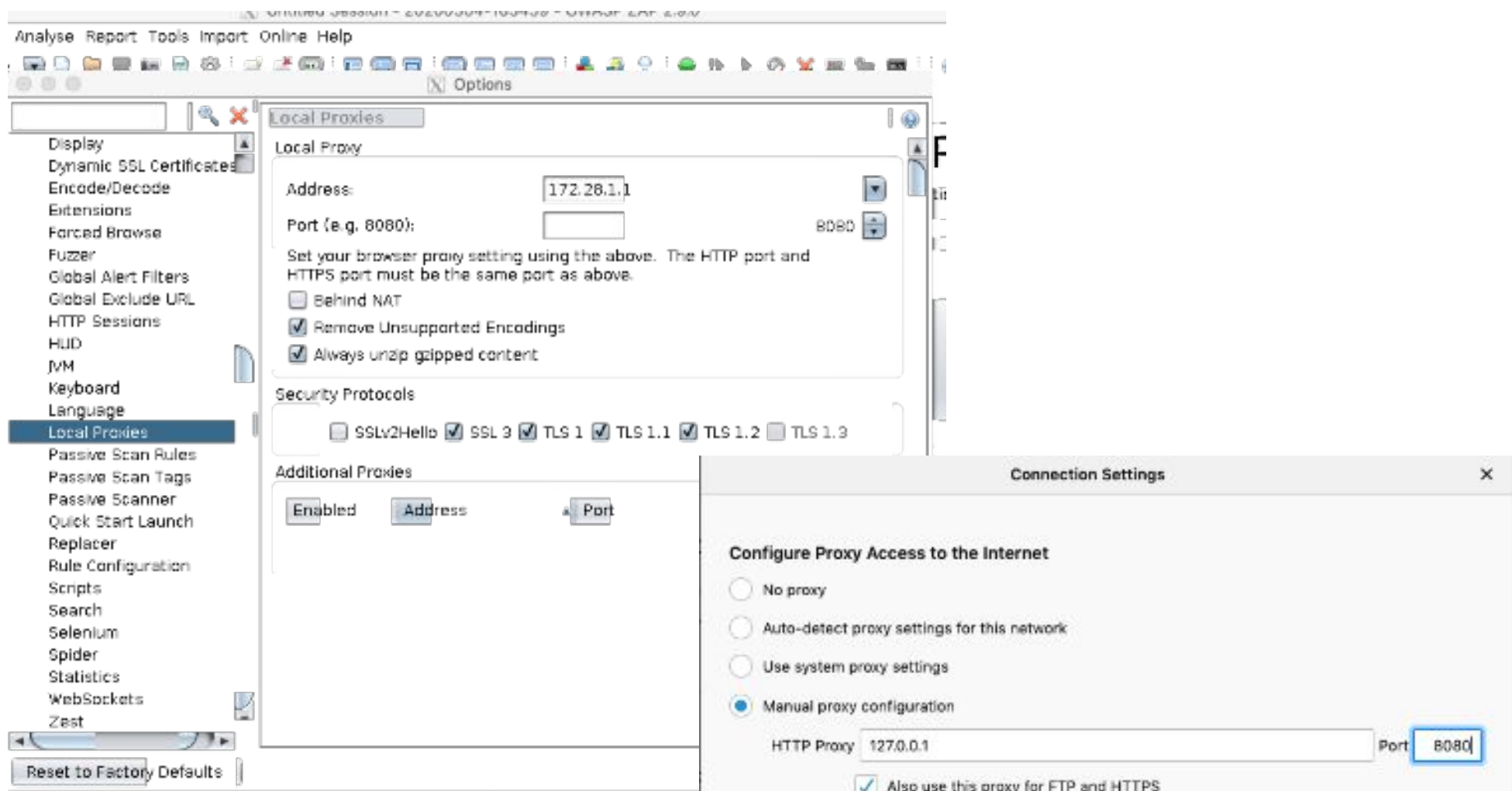
- ▶ <http://www.owasp.org>
- Open group focused on understanding and improving the security of web applications and web services!
- Hundreds of volunteer experts from around the world



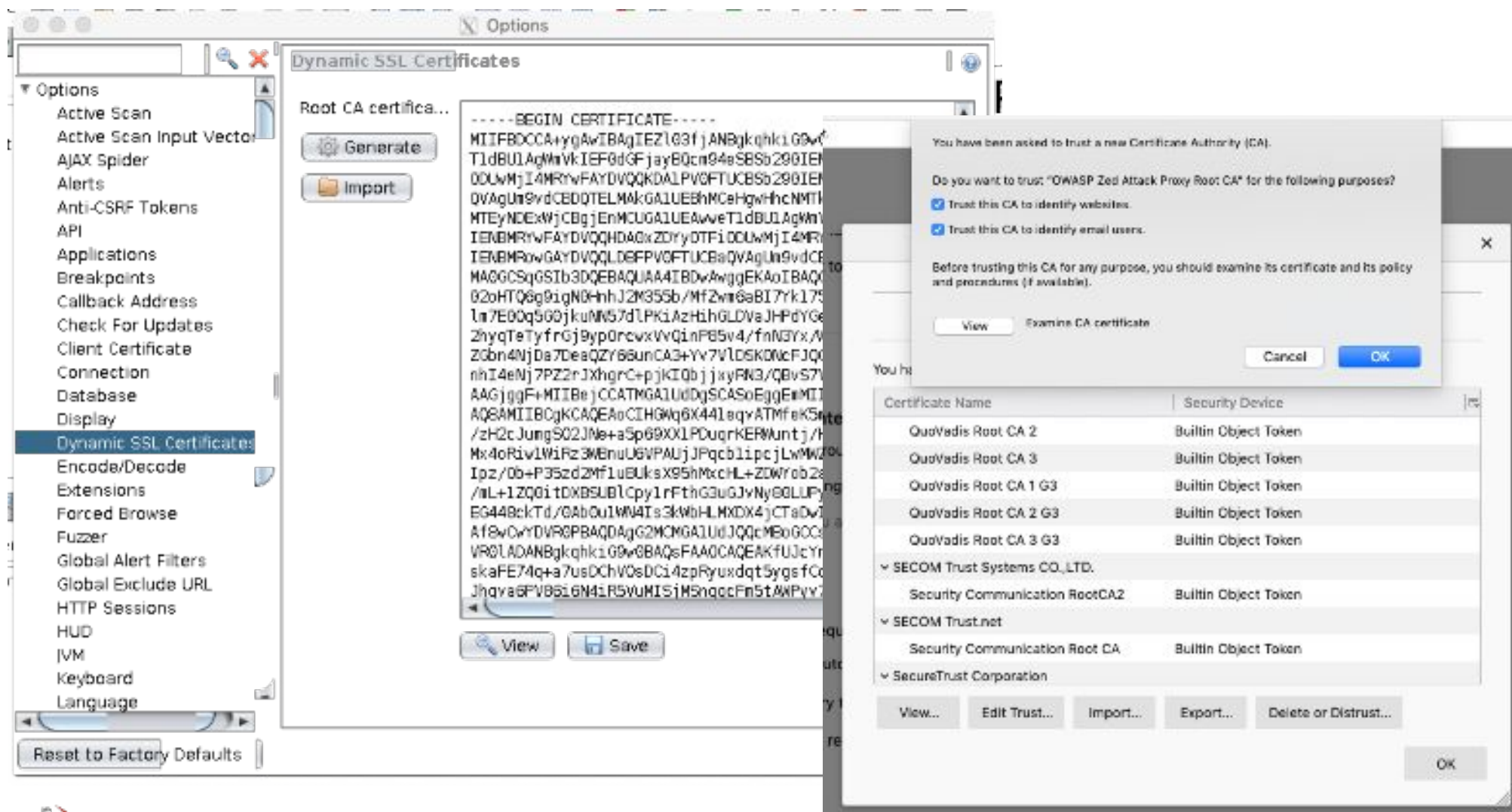
OWASP

The Open Web Application Security Project
<http://www.owasp.org>

ZAP Proxy



ZAP Proxy



Discussion

